Informe de seguridad de Bugambilia

UNIDAD II · OWASP MASVS 2.1.0

Andrey García
Universidad Tecnológica de Gutiérrez Zamora
Fecha de revisión: 27 de octubre de 2026

Ponderación indicada: 40% de la calificación de la Unidad II. Heteroevaluación.

Resumen ejecutivo

La revisión encontró diez problemas de implementación y configuración en Bugambilia. Se corrigieron los flujos de registro y acceso y se incorporaron defensas frente a consultas SQL inseguras, CSRF, sesiones incompletas, entradas inválidas y exposición de archivos y errores. Las 32 comprobaciones de la versión corregida finalizaron satisfactoriamente en el laboratorio.

El archivo entregado contiene una **aplicación web PHP, HTML y JavaScript**, sin proyecto Android ni iOS. MASVS se utiliza como referencia académica adaptada al alcance web. Los controles nativos que no corresponden se justifican individualmente. Este informe no constituye una certificación de conformidad MASVS.

Resultado	Evidencia
10 hallazgos documentados	Ficha individual con reproducción, riesgo, corrección y reprueba.
32 de 32 comprobaciones satisfactorias	Registro, acceso, sesiones, CSRF, límites, eliminación, cabeceras y errores.
24 controles revisados en checklist	C* en alcance web, NC y N/A justificados.
Verificaciones pendientes	TLS desplegado, revisión de componentes y límites de privacidad.
Dos ramas publicadas en GitHub	unidad-ii-base y unidad-ii-corregida; archivo Git portable incluido.

Estado de publicación

Las ramas se publicaron en TheFrisk777/Seguridad y se verificaron contra las referencias remotas. unidad-ii-base conserva el proyecto original y unidad-ii-corregida contiene las correcciones, el informe y las evidencias. Se entrega también un Git bundle con ambas ramas y su historial.

Alcance e inventario

Objeto: carpeta Bugambilia del ZIP AndreyGarcia_U2Act1(1).zip, con 63 archivos. Se conservaron los originales en la rama base antes de editar. La guía de evaluación fue Tarea Movil Integral.pptx, diapositivas 48 a 58. La versión de referencia se fijó en OWASP MASVS 2.1.0 [1].

Elemento	Inventario y tratamiento
Cliente	HTML, CSS y JavaScript. Navegación, registro, acceso, carrito y páginas informativas. Sin app instalada, Manifest, permisos móviles, WebView ni API nativa.
Servidor y DB	PHP con mysqli y esquema MariaDB/MySQL. users, Events, donations, categories, plants y sales. La corrección añade auth_attempts.
Datos	Nombre, correo ficticio y hash bcrypt. Cookie opaca de sesión y token CSRF. Sin datos de clientes reales, pagos, tarjetas ni tokens de servicios externos.
Almacenamiento	Sin persistencia de credenciales en Web Storage. Sesiones PHP y log técnico en runtime privado. DB en instancia local aislada.
Servicios externos	El original referencia Google Fonts, cdnjs e imágenes externas. Se retiraron las cargas automáticas; los enlaces sociales permanecen como navegación voluntaria.
Entorno	Windows, Chrome de pruebas, PHP 8.2.12 y MariaDB 10.4.32. Original: 127.0.0.1:8765; corregido: :8766; rechazo HTTP: :8767; error controlado: :8768. Instancia DB aislada: :13316.

Procedimiento de prueba

1. Extraer e inventariar el ZIP, calcular hashes y congelar la rama original. 2. Revisar código, formularios, SQL, almacenamiento, recursos externos y configuración. 3. Importar el esquema en una instancia aislada y ejecutar el original con datos ficticios. 4. Registrar siete observaciones y capturas. 5. Corregir y migrar la base de pruebas. 6. Ejecutar la suite de 32 comprobaciones mediante Chrome y peticiones HTTP. 7. Revisar capturas y registrar cambios en Git.

Las pruebas de caducidad envejecen únicamente archivos de sesiones ficticias mediante PHP CLI. No representan una espera real de quince minutos. La prueba de SQL con comilla verifica sintaxis y manejo como dato, sin afirmar exfiltración. No se atacaron GitHub, redes sociales, servicios públicos ni la base habitual del equipo.

Protección de las evidencias

Se omitieron contraseñas, cookies, tokens y hashes de cuentas de prueba. En la captura original de error se sustituyó la ruta personal por [RUTA LOCAL OCULTA]. Los visores de código identifican la rama y los números de línea; el hash público de relleno se enmascaró. Se conserva resolución completa de las imágenes en la carpeta de auditoría.

Checklist de controles MASVS

Datos autenticación y comunicaciones

C*: cumple en el alcance web delimitado, sin certificar la totalidad del control móvil. **NC**: no cumple o no está completamente verificado. **N/A**: no aplica, con justificación. Cada fila corresponde a un control específico de MASVS 2.1.0.

Control y revisión	Antes / después	Prueba justificación y límites
MASVS-STORAGE-1 Datos locales sensibles	NC → C*	VULN-02; T05, T10, T22 Sin credenciales en Web Storage. Hash bcrypt en servidor. C* solo para cliente web y configuración examinada; no audita cifrado físico del disco.
MASVS-STORAGE-2 Exposición involuntaria	NC → C*	VULN-07 y VULN-08; T02-T04, T31 Errores y SQL protegidos por router; no-store. ACL y copias del servidor se verifican al desplegar.
MASVS-CRYPTO-1 Criptografía y aleatoriedad	C* → C*	T10; bootstrap.php bcrypt ya existía en el registro original. Se verifica y conserva. CSRF usa random_bytes; no se implementó cifrado propio.
MASVS-CRYPTO-2 Gestión de claves criptográficas	N/A → N/A	Inventario de código No existen claves de cifrado, firma ni keystore propios. La contraseña de DB es una credencial y se revisa en VULN-02. TLS se evalúa en NETWORK.
MASVS-AUTH-1 Autenticación y autorización	NC → C*	VULN-03 a VULN-06; T01, T06-T28 Registro, acceso, sesión, cierre y bloqueo verificados. Una sesión de cuenta; no hay roles administrativos ni API comercial.
MASVS-AUTH-2 Autenticación local del dispositivo	N/A → N/A	Inventario de plataforma Sin PIN ni biometría local. La contraseña se valida en el servidor, no en el dispositivo.
MASVS-AUTH-3 Autenticación adicional de operación sensible	NC → C*	T25-T26 Eliminar cuenta requiere contraseña actual, identidad y CSRF. No hay pagos ni donaciones reales.
MASVS-NETWORK-1 Protección de tráfico	NC → NC	VULN-09; T30 Se probó el rechazo de HTTP de producción. Certificado, negociación TLS y cookie Secure en HTTPS siguen sin verificar.
MASVS-NETWORK-2 Fijación de identidad del endpoint	N/A → N/A	Inventario de cliente Navegación web sin cliente nativo ni API separada bajo su control; no hay pinning de certificados implementable desde este código. La confianza del navegador depende de TLS válido.

La adaptación relaciona riesgos del servidor y del navegador con las áreas MASVS; no convierte la revisión del backend en una prueba de controles nativos. El checklist editable está en auditoria/checklist_masvs.csv.

Checklist de controles MASVS

Plataforma y calidad del código

C*: cumple en el alcance web delimitado, sin certificar la totalidad del control móvil. **NC**: no cumple o no está completamente verificado. **N/A**: no aplica, con justificación. Cada fila corresponde a un control específico de MASVS 2.1.0.

Control y revisión	Antes / después	Prueba justificación y límites
MASVS-PLATFORM-1 IPC y componentes móviles	N/A → N/A	Inventario de archivos No hay APK/IPA, Manifest, Intents, ContentProviders ni enlaces profundos de una app instalada.
MASVS-PLATFORM-2 Seguridad de WebViews	N/A → N/A	Inventario de archivos No hay WebView embebida ni puentes JavaScript nativos. Se utiliza el navegador; no se confunde una página HTML con una WebView.
MASVS-PLATFORM-3 Interfaz y exposición de información	NC → C*	T04-T05, T12, T29 Codificación de salida y campos password. Un navegador no permite impedir capturas de pantalla del sistema. No hay vistas con pagos o tokens visibles.
MASVS-CODE-1 Versión de plataforma móvil	N/A → N/A	Inventario de plataforma No hay minSdkVersion, targetSdkVersion ni sistema móvil objetivo. La actualización de PHP y del navegador queda en el inventario y operación.
MASVS-CODE-2 Componentes sin vulnerabilidades conocidas	NC → NC	Inventario PHP 8.2.12, MariaDB 10.4.32 Se retiraron dependencias front-end remotas. No se ejecutó un análisis CVE completo del runtime ni se actualizaron los binarios del equipo. Requiere revisión antes de producción.
MASVS-CODE-3 Actualización segura de la aplicación	N/A → N/A	Modelo de distribución No hay paquete instalado ni actualizador propio. La entrega web depende del despliegue y HTTPS; el control de distribución nativa no aplica.
MASVS-CODE-4 Validación de datos no confiables	NC → C*	VULN-01, VULN-06, VULN-07; T07, T12-T14, T29, T31 Validación servidor, consultas preparadas, salida codificada y errores controlados. El carrito sigue siendo demostrativo y su precio no autoriza una venta.

La adaptación relaciona riesgos del servidor y del navegador con las áreas MASVS; no convierte la revisión del backend en una prueba de controles nativos. El checklist editable está en auditoria/checklist_masvs.csv.

Checklist de controles MASVS

Resistencia y privacidad

C*: cumple en el alcance web delimitado, sin certificar la totalidad del control móvil. **NC**: no cumple o no está completamente verificado. **N/A**: no aplica, con justificación. Cada fila corresponde a un control específico de MASVS 2.1.0.

Control y revisión	Antes / después	Prueba justificación y límites
MASVS-RESILIENCE-1 Integridad de plataforma	N/A → N/A	Modelo de amenazas Sin ejecutable móvil ni operaciones financieras. Detección root/jailbreak no corresponde a este sitio.
MASVS-RESILIENCE-2 Resistencia a manipulación	N/A → N/A	Modelo de amenazas El cliente web es observable y modificable; la autoridad está en el servidor. Sin binario móvil al que aplicar anti-tampering.
MASVS-RESILIENCE-3 Resistencia al análisis estático	N/A → N/A	Modelo de amenazas JavaScript público sin secretos y sin lógica comercial sensible. No se exige ofuscación de una app instalada.
MASVS-RESILIENCE-4 Resistencia al análisis dinámico	N/A → N/A	Modelo de amenazas No hay DRM, wallet, secretos de cliente ni transacciones que justifiquen anti-debug móvil. La inspección de DevTools no se trata como vulnerabilidad.
MASVS-PRIVACY-1 Minimizar datos y recursos	NC → C*	VULN-10; T21-T22, T32 Solo nombre y correo ficticios, sin apellido. Cámara, micrófono, ubicación y pagos bloqueados por política. No hay permisos móviles.
MASVS-PRIVACY-2 Prevenir identificación del usuario	NC → NC	VULN-10; T21, privacidad.html Se eliminan cargas automáticas de terceros, pero la cuenta usa correo y hay hash temporal de IP para limitar intentos. No se afirma anonimato ni cumplimiento pleno.
MASVS-PRIVACY-3 Transparencia del tratamiento	NC → C*	T32; privacidad.html Aviso de propósito, cookies, datos y retención de la demo. La revisión legal de un servicio real queda fuera del alcance académico.
MASVS-PRIVACY-4 Control del usuario sobre sus datos	NC → C*	T25-T26 Eliminación de la cuenta de prueba confirmada en DB. Las tablas comerciales no tienen operaciones activas ni datos personales de prueba.

La adaptación relaciona riesgos del servidor y del navegador con las áreas MASVS; no convierte la revisión del backend en una prueba de controles nativos. El checklist editable está en auditoria/checklist_masvs.csv.

Hallazgos y priorización

Se utiliza la matriz didáctica de la diapositiva 52: riesgo = impacto × probabilidad. Cada factor toma valores de 1 a 3. Bajo: 1 a 3; medio: 4 a 6; alto: 7 a 8; crítico: 9. Esta escala no es oficial de OWASP. Con factores enteros de 1 a 3 no se obtienen productos 7 u 8; se conserva la clasificación de la rúbrica sin inventar puntuaciones.

ID	Problema	I	P	Riesgo
VULN-01	Consultas SQL construidas con entradas del usuario	3	2	6 Medio
VULN-02	Conexión de base de datos con usuario privilegiado	3	2	6 Medio
VULN-03	Registro e inicio de sesión incompatibles con el esquema	2	3	6 Medio
VULN-04	Control de acceso y ciclo de sesión incompletos	3	2	6 Medio
VULN-05	Formularios sin verificación de origen mediante CSRF	2	2	4 Medio
VULN-06	Validación de entradas insuficiente en el servidor	2	2	4 Medio
VULN-07	Errores técnicos visibles en la respuesta	2	3	6 Medio
VULN-08	Archivo de base de datos descargable desde la web	2	3	6 Medio
VULN-09	Sin obligación de HTTPS ni política de seguridad del navegador	3	2	6 Medio
VULN-10	Tratamiento de datos sin información y con recursos externos	2	2	4 Medio

Impacto 1: efecto limitado; 2: afectación de integridad, disponibilidad o exposición de información técnica; 3: posible compromiso de identidad o datos. Probabilidad 1: condiciones poco comunes; 2: requiere condiciones o explotación adicional; 3: ocurre de forma directa con entradas o peticiones corrientes. Los escenarios potenciales no se presentan como explotaciones exitosas.

Criterio de cierre

Nueve fichas quedan corregidas en el alcance probado. VULN-09 se considera mitigado por configuración, con cierre completo pendiente de TLS real. Las fichas agrupan causas relacionadas; no se cuentan como fallos distintos cada atributo de cookie ni cada cabecera añadida. Las mejoras del carrito se tratan como endurecimiento, porque no se demostró una fuente externa explotable de contenido.

VULN-01 Consultas SQL construidas con entradas del usuario

Referencia: MASVS-CODE-4
Ubicación: Bugambilia/conexion/inde.php
Riesgo inicial: impacto 3 × probabilidad 2 = 6 (Medio).

Resultado antes. B06: un correo con una comilla altera la sintaxis SQL y expone un error. El código concatena nombre, correo y contraseña derivada en SELECT e INSERT. No se demostró extracción de datos ni un acceso exitoso mediante inyección.

Reproducción. Importar el esquema original en la instancia de pruebas. Enviar POST a conexion/inde.php con Registrarse=1, nombre=Demo, apellido=Prueba, email=' y una contraseña ficticia. Observar el error SQL. Revisar las consultas concatenadas.

Corrección implementada. Sustituir todas las consultas con datos externos por prepare y bind_param. Validar correo antes de consultar. La base no interpreta la entrada como parte de SQL.

Repetición de la prueba. T13 rechaza la expresión SQL con 422. T14 envía un correo válido que contiene apóstrofo y obtiene 401, sin error SQL. T08 y T15 confirman que el flujo válido funciona.

Estado y riesgo residual. Corregido en alcance probado. Bajo en los endpoints examinados. No sustituye la revisión de futuros endpoints.

VULN-01 Consultas SQL construidas con entradas del usuario

Extractos reales de código. Antes: rama unidad-ii-base. Después: archivos corregidos.

ANTES · Bugambilia/conexion/inde.php

```
013     $nr =mysqli_num_rows($queryusuario);
014
015     if($nr == 0)
016     {
017         $pass_fuerte = password_hash($contraseña, PASSWORD_BCRYPT);
018         $queryregistrar = "INSERT INTO users (name,email,psswd) values ('$nombre','$email','$pass_fuerte')";
```

DESPUÉS · Bugambilia/conexion/inde.php

```
013     $hash=password_hash($password,PASSWORD_BCRYPT);
014     $stmt=db()->prepare('INSERT INTO users (name,email,psswd,rol) VALUES (?,?,?,0)');
015     $stmt->bind_param('sss',$name,$email,$hash);
016     try { $stmt->execute(); } catch(mysqli_sql_exception $e) { if ($e->getCode()!==1062) { throw $e; } }
```

E12. Extractos de código antes y después. Evidencias relacionadas: B06, T08, T13-T15.

VULN-02 Conexión de base de datos con usuario privilegiado

Referencia: MASVS-STORAGE-1 y CODE-4 por adaptación web
Ubicación: Bugambilia/conexion/conexion.php
Riesgo inicial: impacto 3 × probabilidad 2 = 6 (Medio).

Resultado antes. El código fija localhost, usuario root, contraseña vacía y base bugambilia. No se encontró una clave de producción en el ZIP; el riesgo procede de ejecutar la aplicación con privilegios excesivos y configuración embebida.

Reproducción. Leer conexion.php. Identificar el usuario root y la contraseña vacía. Revisar el alcance de privilegios que tendría la aplicación con esa configuración. No modificar cuentas del MySQL habitual del equipo.

Corrección implementada. Obtener credenciales del entorno. Rechazar root, contraseña vacía y el marcador de ejemplo. Crear una cuenta exclusiva con SELECT, INSERT, UPDATE y DELETE en la base aislada. Excluir .env y runtime de Git.

Repetición de la prueba. T08-T17 funcionan con bugambilia_app. T31 fuerza DB_USER=root en otro servidor y recibe 503 genérico. La cuenta y contraseña aleatoria del laboratorio no se publican.

Estado y riesgo residual. Corregido en alcance probado. Verificar privilegios, rotación de credenciales y ACL del servidor de destino. No se cambió el root del equipo.



VULN-02 Conexión de base de datos con usuario privilegiado

Extractos reales de código. Antes: rama unidad-ii-base. Después: archivos corregidos.

ANTES · Bugambilia/conexion/conexion.php

```
001  <?php
002  $conn = new mysqli("localhost","root","","bugambilia");
003
004  if($conn->connect_errno){
005      echo "No hay conexión: (" . $conn->connect_errno . ") " . $conn->connect_errno;
006  }
007  ?>
```

DESPUÉS · Bugambilia/conexion/conexion.php

```
007      $user=getenv('DB_USER'); $pass=getenv('DB_PASSWORD');
008      if (!$user || strtolower($user)==='root' || !$pass || $pass==='REPLACE_OUTSIDE_GIT') { throw new
RuntimeException('Invalid database configuration'); }
009      mysqli_report(MYSQLI_REPORT_ERROR|MYSQLI_REPORT_STRICT);
010      $conn=new mysqli(getenv('DB_HOST') ?: '127.0.0.1',$user,$pass,getenv('DB_NAME') ?: 'bugambilia',(int)
(getenv('DB_PORT') ?: 3306));
011      $conn->set_charset('utf8mb4');
012      return $conn;
013  }
```

E13. Extractos de código antes y después. Evidencias relacionadas: T08-T17, T31.

VULN-03 Registro e inicio de sesión incompatibles con el esquema

Referencia: MASVS-AUTH-1 y CODE-4 por adaptación web
Ubicación: paginas/inde.html, conexion/inde.php y BD/bugambilia.sql
Riesgo inicial: impacto 2 × probabilidad 3 = 6 (Medio).

Resultado antes. B01: el formulario de acceso hace POST a su propio HTML. B02: users.id_user no tiene AUTO_INCREMENT y el INSERT no aporta ID. B03: el acceso consulta login y pass, pero el esquema contiene users y psswd.

Reproducción. Importar el SQL original con modo estricto. Abrir paginas/inde.html y registrar una cuenta ficticia. Observar el error id_user. Enviar el inicio de sesión directamente a conexion/inde.php y comprobar la tabla login inexistente.

Corrección implementada. Usar inde.php para generar los formularios, dirigir ambos POST al controlador, consultar users.psswd y obtener el nombre desde la base. Incorporar AUTO_INCREMENT, NOT NULL e índice UNIQUE de correo. Entregar migración para la base original.

Repetición de la prueba. T08 crea cuenta, T09 confirma una fila con ID automático, T11 evita duplicados y T15-T17 permiten entrar a Mi cuenta. E02 muestra el error original y E07 la pantalla corregida.

Estado y riesgo residual. Corregido en alcance probado. Los módulos de compras, donaciones y contacto siguen como demostraciones; no se implementó procesamiento comercial.

VULN-03 Registro e inicio de sesión incompatibles con el esquema

Extractos reales de código. Antes: rama unidad-ii-base. Después: archivos corregidos.

ANTES · Bugambilia/conexion/inde.php

```
036  //Para iniciar sesión
037  if(isset($_POST["IniciarSesion"])){
038      $queryusuario = mysqli_query($conn,"SELECT * FROM login WHERE email = '$email'");
039      $nr =mysqli_num_rows($queryusuario);
040      $mostrar = mysqli_fetch_array($queryusuario);
041
042      if(($nr == 1) && (password_verify($contraseña,$mostrar['pass']))){
043          session_start();
```

DESPUÉS · Bugambilia/conexion/inde.php

```
035  $stmt=$c->prepare('SELECT id_user,name,psswd FROM users WHERE email=? LIMIT 1');
036  $stmt->bind_param('s',$email);$stmt->execute();$user=$stmt->get_result()->fetch_assoc();
037  $dummy='[HASH DE RELLENO OCULTO]';
038  $valid=password_verify($password,$user['psswd'] ?? $dummy);
039  if (!$user || !$valid) { fail(401,'Correo o contraseña incorrectos.'); }
040  session_regenerate_id(true);
041  $_SESSION=['user_id'=>
(int)$user['id_user'],'name'=>$user['name'],'created_at'=>time(),'last_seen'=>time(),'csrf'=>bin2hex(random_bytes
(32))];
042  header('Location: /Bugambilia/conexion/principal.php',true,303);
```

E14. Extractos de código antes y después. Evidencias relacionadas: B01-B03, E01-E02, E07-E08, T08-T17.

VULN-04 Control de acceso y ciclo de sesión incompletos

Referencia: MASVS-AUTH-1
Ubicación: Bugambilia/conexion/principal.php y controlador de acceso
Riesgo inicial: impacto 3 × probabilidad 2 = 6 (Medio).

Resultado antes. B05 devuelve 200 sin sesión y sin denegación explícita. El principal original destruye la sesión cuando existe y redirige a bug2.html, ausente. No establece caducidad, regeneración ni cierre mediante una operación separada. La página original está vacía, por lo que no se afirma exposición de datos privados.

Reproducción. Solicitar principal.php sin cookies. Revisar la condición isset original y session_destroy. Buscar session_regenerate_id, last_seen, configuración HttpOnly y un endpoint de cierre; no existen en el proyecto original.

Corrección implementada. Exigir identidad en principal, renovar ID al autenticar, usar cookies HttpOnly y SameSite=Lax, caducidad inactiva de 900 s y absoluta de 3600 s. Cerrar mediante POST con CSRF y destruir la sesión y cookie.

Repetición de la prueba. T01 devuelve 401 sin identidad. T16 verifica cambio del ID. T18-T20 demuestran cierre por POST y rechazo de la cookie anterior. T23-T24 prueban ambas caducidades mediante envejecimiento controlado de sesiones ficticias.

Estado y riesgo residual. Corregido en alcance probado. Cookie Secure y transporte real requieren HTTPS. Las pruebas HTTP locales usan una excepción explícita limitada a loopback.



VULN-04 Control de acceso y ciclo de sesión incompletos

Extractos reales de código. Antes: rama unidad-ii-base. Después: archivos corregidos.

ANTES · Bugambilia/conexion/principal.php

```
003  session_start();
004
005  if(isset($_SESSION['nombredelusuario']))
006  {
007      session_destroy();
008      header('location: bug2.html');
009      exit;
010  }
```

DESPUÉS · Bugambilia/conexion/bootstrap.php

```
029  session_set_cookie_params(['lifetime'=>0,'path'=>'/Bugambilia/','secure'=>!$local ||
$tls,'httponly'=>true,'samesite'=>'Lax']);
030  session_start();
031  if (isset($_SESSION['user_id']) && (time()-($_SESSION['last_seen'] ?? 0)>900 || time()-
($_SESSION['created_at'] ?? 0)>3600)) {
032      clear_session();
033      fail(401,'La sesión ha caducado. Inicia sesión de nuevo.');
034  }
035  if (isset($_SESSION['user_id'])) { $_SESSION['last_seen']=time(); }
036  if (!isset($_SESSION['csrf'])) { $_SESSION['csrf']=bin2hex(random_bytes(32)); }
```

E15. Extractos de código antes y después. Evidencias relacionadas: B05, E04, E07, T01, T05, T16-T24.

VULN-05 Formularios sin verificación de origen mediante CSRF

Referencia: MASVS-AUTH-1 y CODE-4 por adaptación web
Ubicación: paginas/inde.html y conexion/inde.php
Riesgo inicial: impacto 2 × probabilidad 2 = 4 (Medio).

Resultado antes. Los POST originales no contienen ni verifican un token CSRF. Se registra la ausencia de la defensa en código; el registro roto del original impide afirmar una modificación de estado exitosa desde otro sitio.

Reproducción. Inspeccionar los formularios y el controlador original. Enviar una solicitud de registro sin token y verificar que alcanza las consultas de la base en lugar de ser rechazada por origen.

Corrección implementada. Generar un token aleatorio por sesión, incorporarlo como campo oculto y compararlo con hash_equals. Exigir POST y token válido en registro, acceso, cierre y eliminación.

Repetición de la prueba. T06 envía token inválido y recibe 403. T08 y T15 completan operaciones con token correcto. T18 impide cierre mediante GET. La captura E05 muestra el rechazo; los tokens no aparecen en las evidencias.

Estado y riesgo residual. Corregido en alcance probado. Mantener CSP y codificación de salida; una vulnerabilidad XSS futura podría comprometer defensas basadas en tokens.



VULN-05 Formularios sin verificación de origen mediante CSRF

Extractos reales de código. Antes: rama unidad-ii-base. Después: archivos corregidos.

ANTES · Bugambilia/conexion/inde.php

```
003
004  $nombre = $_POST["nombre"];
005  $apellido = $_POST["apellido"];
006  $email = $_POST["email"];
007  $contraseña = $_POST["contraseña"];
008
009  //Para Registrarse
```

DESPUÉS · Bugambilia/conexion/bootstrap.php

```
044  function require_post(): void {
045      if ($_SERVER['REQUEST_METHOD']!=='POST') { header('Allow: POST'); fail(405,'Esta operación requiere
POST.'); }
046      $token=$_POST['csrf'] ?? null;
047      if (!is_string($token) || !hash_equals($_SESSION['csrf'],$token)) { fail(403,'Solicitud rechazada por
protección CSRF. Recarga el formulario.'); }
048  }
```

E16. Extractos de código antes y después. Evidencias relacionadas: B02, E05, T06, T08, T15, T18-T19.

VULN-06 Validación de entradas insuficiente en el servidor

Referencia: MASVS-CODE-4
Ubicación: Bugambilia/conexion/inde.php
Riesgo inicial: impacto 2 × probabilidad 2 = 4 (Medio).

Resultado antes. El controlador lee campos directamente desde POST, incluso nombre y apellido durante el acceso. Confía en required del navegador, no verifica formato, tipo, longitud ni una política de contraseña. B03 produce advertencias al omitir campos.

Reproducción. Enviar un POST directamente al controlador omitiendo nombre o con correo inválido y contraseña breve. Comprobar la lectura de claves inexistentes y la ausencia de validación antes de SQL.

Corrección implementada. Comprobar tipos escalares, formato y límite de correo, nombre de 2 a 80 caracteres y contraseña de 12 a 72 bytes para bcrypt. Rechazar etiquetas en nombre y codificar toda salida variable. Retirar apellido, no utilizado.

Repetición de la prueba. T07 devuelve 422 ante correo inválido y contraseña breve. T12 rechaza etiquetas. T13 rechaza una expresión SQL antes de consultar. T29 prueba construcción del carrito como texto, como endurecimiento adicional.

Estado y riesgo residual. Corregido en alcance probado. La longitud de contraseña en bytes se valida en servidor. El cliente mejora usabilidad y no decide la aceptación.

VULN-06 Validación de entradas insuficiente en el servidor

Extractos reales de código. Antes: rama unidad-ii-base. Después: archivos corregidos.

ANTES · Bugambilia/conexion/inde.php

```
003
004  $nombre = $_POST["nombre"];
005  $apellido = $_POST["apellido"];
006  $email = $_POST["email"];
007  $contraseña = $_POST["contraseña"];
008
```

DESPUÉS · Bugambilia/conexion/inde.php

```
005  $email=strtolower(trim(field('email')));
006  $password=field('contraseña');
007  if (!filter_var($email,FILTER_VALIDATE_EMAIL) || strlen($email)>254 || strlen($password)<12 ||
strlen($password)>72) {
008      fail(422,'Revisa el correo y usa una contraseña de 12 a 72 bytes.');
009  }
010  if (isset($_POST['Registrarse']) && !isset($_POST['IniciarSesion'])) {
011      $name=trim(field('nombre'));
012      if (mb_strlen($name)<2 || mb_strlen($name)>80 || preg_match('/[<>\x00-\x1f]/u',$name)) { fail(422,'El
nombre debe tener de 2 a 80 caracteres y no incluir etiquetas.'); }
```

E17. Extractos de código antes y después. Evidencias relacionadas: B03, E06, T07, T12-T14, T29.

VULN-07 Errores técnicos visibles en la respuesta

Referencia: MASVS-STORAGE-2 y CODE-4 por adaptación web
Ubicación: conexion/conexion.php y conexion/inde.php
Riesgo inicial: impacto 2 × probabilidad 3 = 6 (Medio).

Resultado antes. B02 y B03 exponen rutas absolutas, nombres de tabla, consultas parciales y stack trace con display_errors activo en el laboratorio. La aplicación carece de manejador de excepciones. La exposición depende de la configuración PHP del servidor.

Reproducción. Ejecutar el original con display_errors=1. Enviar el registro válido con el esquema original y observar el error de id_user. Omitir campos en el acceso y comprobar advertencias y tabla inexistente.

Corrección implementada. Desactivar display_errors desde bootstrap y controlar excepciones con 503 genérico. Registrar solo la clase del error en un directorio privado. No registrar SQL, entradas, correos, contraseñas ni identificadores de sesión.

Repetición de la prueba. T31 usa una configuración de base inválida y recibe 503 sin mysqli, ruta, root ni stack trace. E02 y E11 muestran el contraste. La ruta personal del original se ocultó antes de capturar.

Estado y riesgo residual. Corregido en alcance probado. Configurar también display_errors=Off en php.ini del despliegue y aplicar ACL y rotación a los logs.



VULN-07 Errores técnicos visibles en la respuesta

Extractos reales de código. Antes: rama unidad-ii-base. Después: archivos corregidos.

ANTES · Bugambilia/conexion/conexion.php

```
001  <?php
002  $conn = new mysqli("localhost","root","","bugambilia");
003
004  if($conn->connect_errno){
005      echo "No hay conexión: (" . $conn->connect_errno . ") " . $conn->connect_errno;
006  }
007  ?>
```

DESPUÉS · Bugambilia/conexion/bootstrap.php

```
008  set_exception_handler(function(Throwable $e): void {
009      // Never log SQL, input, passwords, email addresses or session identifiers.
010      error_log('Unhandled application exception: '.get_class($e));
011      http_response_code(503);
012      header('Content-Type: text/html; charset=utf-8');
013      echo '<!doctype html><html lang="es"><meta charset="utf-8"><title>Servicio no disponible</title>
<h1>Servicio temporalmente no disponible</h1><p>Intenta de nuevo más tarde.</p></html>';
014  });
```

E18. Extractos de código antes y después. Evidencias relacionadas: B02-B03, E02, E11, T31.

VULN-08 Archivo de base de datos descargable desde la web

Referencia: MASVS-STORAGE-2 por adaptación web
Ubicación: Bugambilia/BD/bugambilia.sql
Riesgo inicial: impacto 2 × probabilidad 3 = 6 (Medio).

Resultado antes. B04 obtiene HTTP 200 y descarga el esquema SQL completo. El archivo original no contiene registros personales ni contraseñas, pero revela estructura interna. No hay reglas de denegación ni separación de archivos privados.

Reproducción. Solicitar /Bugambilia/BD/bugambilia.sql al servidor original. Guardar la respuesta y comprobar CREATE TABLE users y los nombres de columnas. E03 representa el cuerpo real de esa respuesta.

Corrección implementada. Enrutar todas las solicitudes por router.php, permitir solo tipos y endpoints públicos, y denegar BD, archivos ocultos, runtime y rutas de escape. Mantener credenciales, logs y sesiones fuera del contenido servido.

Repetición de la prueba. T02 devuelve 404 para el mismo SQL. T03 devuelve 404 para .env. El archivo permanece en el repositorio para instalación autorizada, pero no se entrega por HTTP bajo el servidor configurado.

Estado y riesgo residual. Corregido en alcance probado. Es obligatorio usar el router o reglas equivalentes del servidor. Servir directamente la carpeta como estáticos volvería a exponer el SQL.

VULN-08 Archivo de base de datos descargable desde la web

Extractos reales de código. Antes: rama unidad-ii-base. Después: archivos corregidos.

ANTES · Bugambilia/BD/bugambilia.sql

```
001  create database Bugambilia;
002  use Bugambilia;
003
004  create table users(
005  id_user int primary key,
006  name varchar(80),
007  email varchar (255),
008  rol boolean,
009  psswd varchar (255)
```

DESPUÉS · router.php

```
004  $path=rawurldecode(parse_url($_SERVER['REQUEST_URI'],PHP_URL_PATH) ?: '/');
005  if (str_contains($path,"\0") || str_contains($path,'\\') || preg_match('~
(^|/)\.|/BD(?:/|$)|/runtime(?:/|$)~i',$path)) { fail(404,'Recurso no disponible.'); }
006  if ($path==='/') { header('Location: /Bugambilia/index.html',true,302);exit; }
007  if ($path==='/Bugambilia/paginas/inde.html') { header('Location:
/Bugambilia/paginas/inde.php',true,302);exit; }
008  $base=realpath(__DIR__.'/Bugambilia');$file=realpath(__DIR__.$path);
009  if (!$file || !str_starts_with($file,$base.DIRECTORY_SEPARATOR) || !is_file($file)) { fail(404,'Recurso no
disponible.'); }
010  if (str_ends_with($path,'.php')) {
```

E19. Extractos de código antes y después. Evidencias relacionadas: B04, E03, T02-T03.

VULN-09 Sin obligación de HTTPS ni política de seguridad del navegador

Referencia: MASVS-NETWORK-1
Ubicación: Configuración de entrega y bootstrap.php
Riesgo inicial: impacto 3 × probabilidad 2 = 6 (Medio).

Resultado antes. B07 entrega el formulario por HTTP sin impedir el envío de credenciales por ese canal. No se suministra configuración TLS, CSP, no-store ni restricción de capacidades. No se interceptó tráfico real ni se ensayaron servicios externos.

Reproducción. Solicitar el formulario por HTTP al servidor original. Revisar esquema de URL y cabeceras. Repetir la petición contra la configuración corregida con ALLOW_LOCAL_HTTP=0.

Corrección implementada. Rechazar HTTP con 426 fuera del laboratorio autorizado en loopback. Activar Secure en la cookie bajo HTTPS y HSTS únicamente cuando hay TLS. Añadir CSP, no-store, nosniff, no-referrer y Permissions-Policy.

Repetición de la prueba. T30 confirma 426 con modo de producción y T04 verifica cabeceras. T05 comprueba atributos de cookie en HTTP local, donde Secure=false está limitado a la excepción de pruebas. No se ha instalado ni validado un certificado de producción.

Estado y riesgo residual. Mitigado con pendiente TLS. Pendiente de cierre completo: desplegar TLS válido, verificar cadena y nombre del certificado, protocolo y cookie Secure por HTTPS. NETWORK-1 conserva NC.

VULN-09 Sin obligación de HTTPS ni política de seguridad del navegador

Extractos reales de código. Antes: rama unidad-ii-base. Después: archivos corregidos.

ANTES · Bugambilia/paginas/inde.html

```
005      <meta name="viewport" content="width=device-width, initial-scale=1.0">
006      <!-- ESTILOS -->
007      <link rel="preconnect" href="https://fonts.googleapis.com">
008      <link rel="preconnect" href="https://fonts.gstatic.com" crossorigin>
009      <link href="https://fonts.googleapis.com/css2?family=Barlow&display=swap" rel="stylesheet">
010      <!-- FIN DE ESTILOS-->
011      <link rel="stylesheet" href="https://cdnjs.cloudflare.com/ajax/libs/font-awesome/6.5.2/css/all.min.css"
012      integrity="sha512-
SnH5WK+bZxgPHs44uWIX+LLJAJ9/2PkPKZ5QiAj6Ta86w+fsb2TkcmfRyVX3pBnMFcV7oQPJkl9QevSCWr3W6A=="
```

DESPUÉS · Bugambilia/conexion/bootstrap.php

```
020  header('Permissions-Policy: camera=(), microphone=(), geolocation=(), payment=()');
021  header("Content-Security-Policy: default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline';
img-src 'self' data:; font-src 'self'; connect-src 'self'; form-action 'self'; frame-ancestors 'none'; base-uri
'none'; object-src 'none'");
022  header('Cache-Control: no-store, private');
023  if ($tls) { header('Strict-Transport-Security: max-age=31536000'); }
024  if (!$tls && !$local) { fail(426,'Se requiere HTTPS para utilizar la aplicación.'); }
```

E20. Extractos de código antes y después. Evidencias relacionadas: B07, E10, T04-T05, T30.

VULN-10 Tratamiento de datos sin información y con recursos externos

Referencia: MASVS-PRIVACY-1, PRIVACY-2, PRIVACY-3 y PRIVACY-4 por adaptación web
Ubicación: Plantillas HTML, formulario y flujo de cuenta
Riesgo inicial: impacto 2 × probabilidad 2 = 4 (Medio).

Resultado antes. El registro solicita apellido pero el servidor no lo guarda. Varias páginas cargan fuentes y CSS externos automáticamente. No hay aviso sobre uso y conservación de datos ni opción para eliminar la cuenta. No se investigaron las prácticas de seguimiento de esos proveedores.

Reproducción. Revisar los link de fonts.googleapis.com, fonts.gstatic.com y cdnjs.cloudflare.com. Comparar campos del formulario con INSERT. Buscar aviso de privacidad y eliminación de cuenta; no existen en la base.

Corrección implementada. Retirar cargas externas automáticas y el apellido, informar sobre cookies, propósito y retención, y permitir eliminar la cuenta mediante contraseña actual y CSRF. Mantener enlaces sociales como navegación voluntaria.

Repetición de la prueba. T21 registra cero solicitudes automáticas a terceros durante el flujo inspeccionado. T22 no encuentra credenciales en Web Storage. T25 exige reautenticación y T26 comprueba eliminación. T32 confirma el aviso.

Estado y riesgo residual. Corregido en alcance probado. El correo sigue siendo un identificador necesario de cuenta. PRIVACY-2 no se declara plenamente cumplido. Implementar purga programada de logs/sesiones y avisos legales antes de uso real.

VULN-10 Tratamiento de datos sin información y con recursos externos

Extractos reales de código. Antes: rama unidad-ii-base. Después: archivos corregidos.

ANTES · Bugambilia/paginas/inde.html

```
005      <meta name="viewport" content="width=device-width, initial-scale=1.0">
006      <!-- ESTILOS -->
007      <link rel="preconnect" href="https://fonts.googleapis.com">
008      <link rel="preconnect" href="https://fonts.gstatic.com" crossorigin>
009      <link href="https://fonts.googleapis.com/css2?family=Barlow&display=swap" rel="stylesheet">
010      <!-- FIN DE ESTILOS-->
011      <link rel="stylesheet" href="https://cdnjs.cloudflare.com/ajax/libs/font-awesome/6.5.2/css/all.min.css"
012      integrity="sha512-
SnH5WK+bZxgPHs44uWIX+LLJAJ9/2PkPKZ5QiAj6Ta86w+fsb2TkcmfRyVX3pBnMFcV7oQPJkl9QevSCWr3W6A=="
```

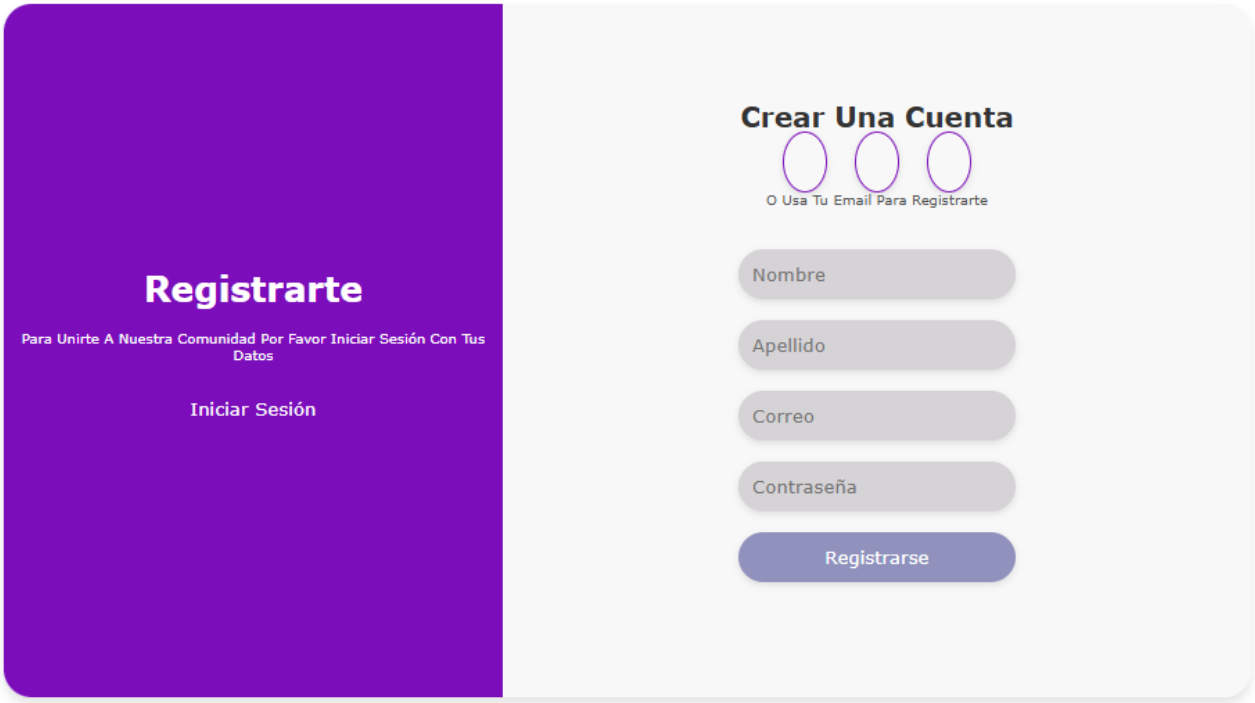
DESPUÉS · Bugambilia/conexion/eliminar.php

```
004  $id=$_SESSION['user_id'];
005  $stmt=db()->prepare('SELECT psswd FROM users WHERE id_user=?');$stmt->bind_param('i',$id);$stmt-
>execute();$user=$stmt->get_result()->fetch_assoc();
006  if (!$user || !password_verify(field('contraseña'),$user['psswd'])) { fail(401,'No se pudo confirmar la
operación.'); }
007  $stmt=db()->prepare('DELETE FROM users WHERE id_user=?');$stmt->bind_param('i',$id);$stmt->execute();
008  clear_session(); header('Location: /Bugambilia/paginas/inde.php?estado=eliminada',true,303);
```

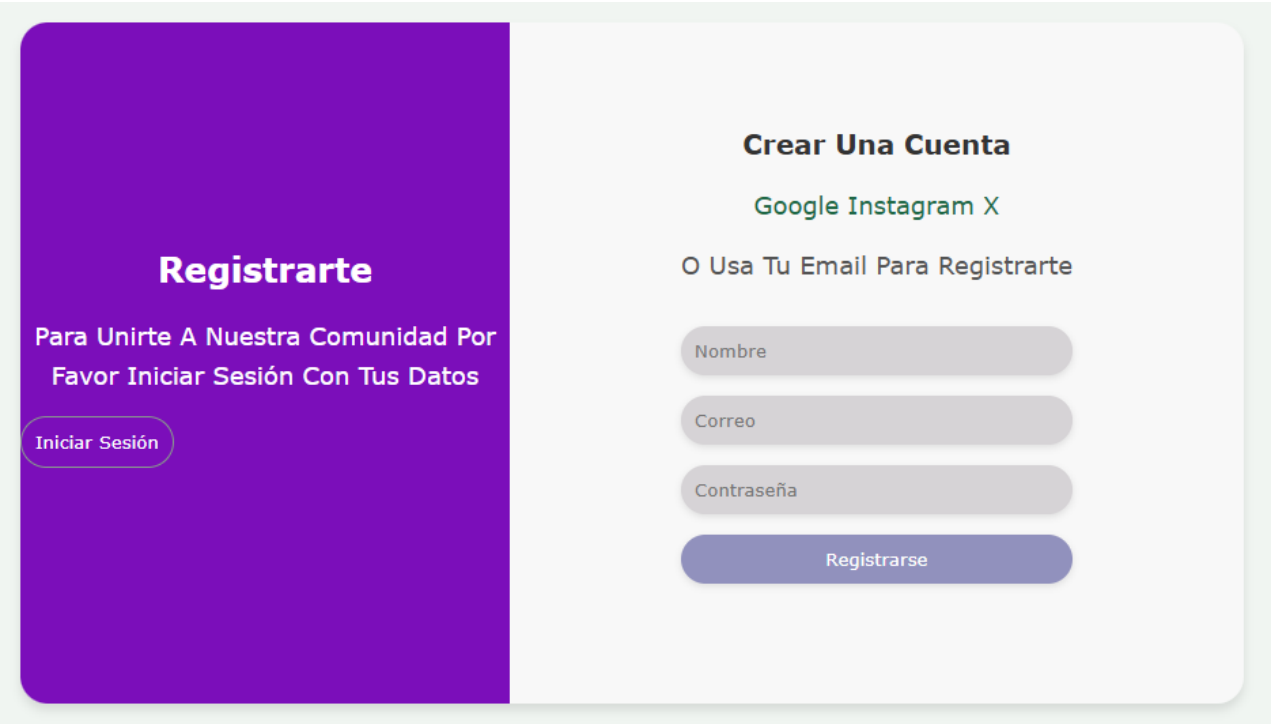
E21. Extractos de código antes y después. Evidencias relacionadas: E08, T21-T22, T25-T26, T32.

Evidencias de ejecución antes y después

Las siguientes capturas provienen de Chrome en el laboratorio. Se muestran recortes para facilitar su lectura; las imágenes completas se conservan en la entrega. E03 muestra en un visor un fragmento del cuerpo SQL realmente descargado, porque el navegador inicia su descarga. E05, E06, E09 y E11 muestran las respuestas HTTP obtenidas por la suite. E12 a E21, en las fichas anteriores, son visores de extractos reales de código.



E01. Registro original: incluye apellido y envía al controlador que falla con el esquema original.



E08. Registro corregido: elimina apellido y usa formulario PHP con CSRF y validación.

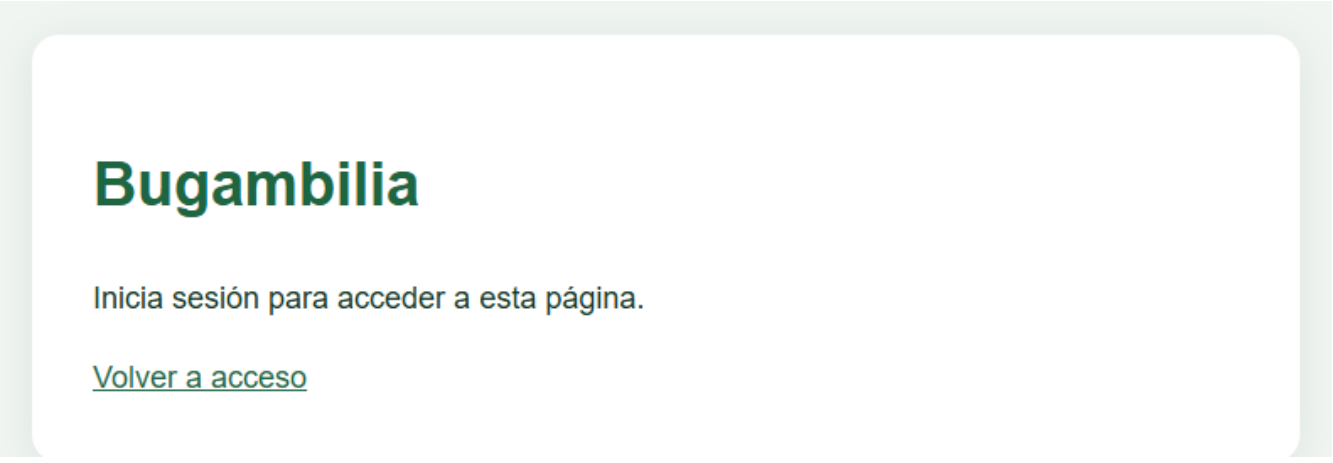
Registro y acceso verificados

Fatal error: Uncaught mysqli_sql_exception: Field 'id_user' doesn't have a default value in [RUTA LOCAL OCULTA]\Bugambilia OCULTA]\Bugambilia\conexion\inde.php(20): mysqli_query(Object(mysqli), 'INSERT INTO use...') #1 {main} thrown in **[RUTA**

E02. Detalle de la captura original: id_user sin valor por defecto y stack trace. Ruta personal enmascarada.



E07. Cuenta Demo después de registro y acceso correctos. T08 a T17 verifican base, hash e identidad.



E04. Acceso anónimo rechazado con 401. La cuenta solo se muestra con una sesión válida.

Archivos y solicitudes rechazadas

Respuesta HTTP real del archivo SQL

GET /Bugambilia/BD/bugambilia.sql · HTTP 200

```
create database Bugambilia;
use Bugambilia;

create table users(
id_user int primary key,
name varchar(80),
email varchar (255),
rol boolean,
psswd varchar (255)
)engine = InnoDB;

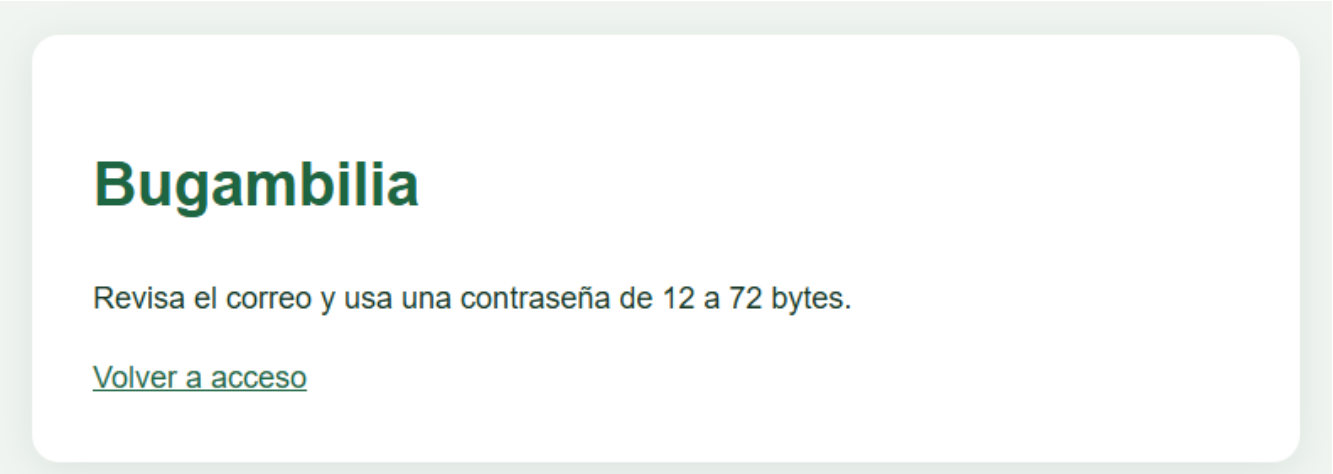
create table Events(
id_event int primary key,
event varchar (255),
descriptione varchar (300),
dateevent date,
img varchar (255)
```

E03. Respuesta HTTP 200 original: el esquema SQL es descargable. La misma ruta devuelve 404 después de la corrección, comprobado en T02.

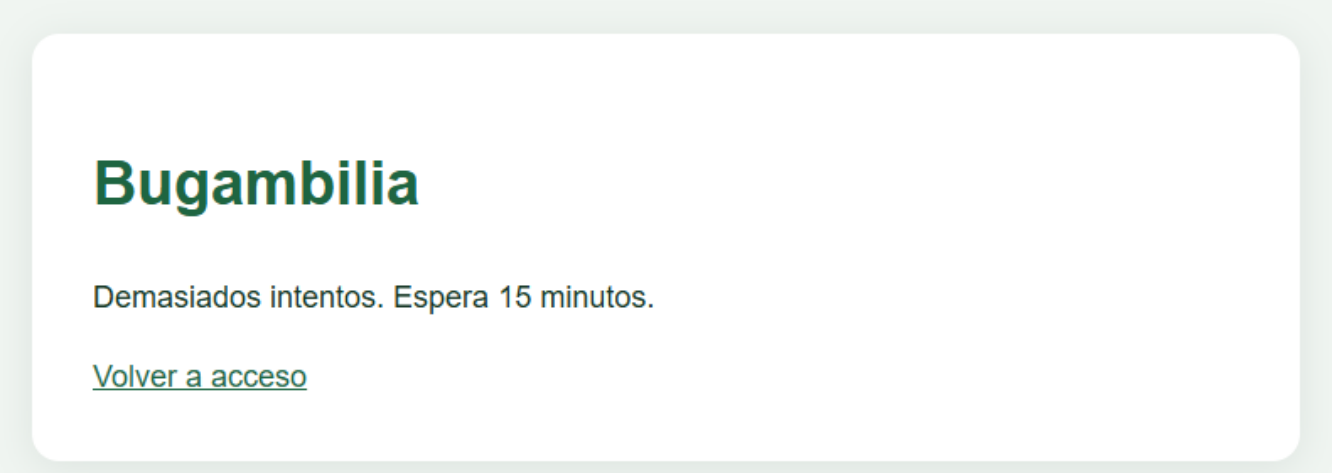


E05. POST con token CSRF inválido: HTTP 403. Los valores de tokens se omiten.

Validación y control de intentos



E06. Datos inválidos rechazados en servidor con HTTP 422, aunque se omita la validación del navegador.



E09. Sexto intento rechazado con HTTP 429. T28 confirma que cambiar la cookie no evita el bloqueo.

Transporte y errores controlados



E10. Configuración de producción: HTTP recibe 426. No demuestra un handshake TLS ni validación de certificado.



E11. Configuración inválida de base: mensaje genérico y HTTP 503, sin ruta personal ni SQL.

Resultados de la repetición de pruebas

Primera parte · 16 comprobaciones

ID	Prueba	Resultado observado
T01	Acceso anónimo	PASS. HTTP 401
T02	SQL no público	PASS. HTTP 404
T03	Configuración no pública	PASS. HTTP 404
T04	Cabeceras de seguridad	PASS. CSP, no-store, Referrer-Policy, Permissions-Policy
T05	Cookie HttpOnly y SameSite	PASS. HttpOnly=true; SameSite=Lax; Secure=false solo en loopback autorizado
T06	CSRF inválido	PASS. HTTP 403
T07	Validación del servidor	PASS. HTTP 422
T08	Registro válido	PASS. HTTP 303
T09	Persistencia con ID automático	PASS. 1 registro con ID generado
T10	Contraseña bcrypt	PASS. Hash bcrypt verificado; valor oculto
T11	Duplicado sin enumeración	PASS. HTTP 303; no duplica cuenta; respuesta uniforme
T12	Etiquetas en nombre	PASS. HTTP 422
T13	Entrada SQL inválida	PASS. HTTP 422; no alcanza SQL
T14	Comilla tratada como dato	PASS. HTTP 401; sin error SQL ni autenticación
T15	Inicio de sesión válido	PASS. HTTP 303
T16	Renovación del ID	PASS. ID cambia al autenticar; valores ocultos

Fuente reproducible: tests/verify.cjs y auditoria/resultados_corregida.json. Las credenciales y los identificadores de sesión no se registran en el resultado. La suite se ejecuta exclusivamente sobre una instancia de pruebas; borra contadores de intentos y elimina su cuenta ficticia.

Resultados de la repetición de pruebas

Segunda parte · 16 comprobaciones

ID	Prueba	Resultado observado
T17	Principal autenticado	PASS. Cuenta Demo; HTTP 200
T18	Logout rechaza GET	PASS. HTTP 405
T19	Logout POST	PASS. HTTP 303
T20	Reutilizar cookie revocada	PASS. HTTP 401
T21	Sin peticiones a terceros	PASS. Solicitudes externas automáticas: 0
T22	Almacenamiento del navegador	PASS. localStorage=0; sessionStorage=0
T23	Caducidad por inactividad	PASS. HTTP 401; last_seen retrocedido 901 s en sesión de prueba
T24	Caducidad absoluta	PASS. HTTP 401; created_at retrocedido 3601 s
T25	Eliminar exige reautenticación	PASS. HTTP 401
T26	Eliminación de cuenta	PASS. HTTP 303; cero filas de la cuenta de prueba
T27	Límite persistente de intentos	PASS. 401, 401, 401, 401, 401, 429
T28	Cambiar cookie no evita bloqueo	PASS. HTTP 429
T29	Carrito no interpreta HTML	PASS. Texto literal; solo imagen original del producto
T30	HTTP bloqueado en producción	PASS. HTTP 426 con ALLOW_LOCAL_HTTP=0
T31	Error sin detalles internos	PASS. HTTP 503; mensaje genérico ante DB_USER=root
T32	Aviso y minimización	PASS. Aviso disponible; no se solicita apellido

Fuente reproducible: tests/verify.cjs y auditoria/resultados_corregida.json. Las credenciales y los identificadores de sesión no se registran en el resultado. La suite se ejecuta exclusivamente sobre una instancia de pruebas; borra contadores de intentos y elimina su cuenta ficticia.

Trazabilidad y reproducción

Elemento	Identificador
Rama original	unidad-ii-base
Commit original	e2c355f8b259c350d4c317b1833edb4e8afe8c4c
Rama corregida	unidad-ii-corregida
Commit del código corregido	59dfa8d00af7b57057ca3180b98a898ae07dcb31
ZIP original SHA-256	b603a5eb10462615463d27b19f757d33fa35e78e368d0d72351db4c1f0c8bb19
Repositorio autorizado	https://github.com/TheFrisk777/Seguridad.git

El commit de código anterior congela las correcciones probadas. El informe, checklist y evidencias se incorporan en un commit documental posterior. El Git bundle conserva las dos ramas y su relación de ancestro. Los hashes SHA-256 por archivo original se incluyen en auditoria/sha256_original.json. Git puede normalizar finales de línea de texto; el hash del ZIP identifica el archivo fuente recibido.

Repetir el laboratorio

Clonar Seguridad.bundle o el repositorio publicado. Cambiar a la rama base para repetir B01 a B07 con PHP y una instancia de DB aislada. Usar :13316 para no tocar el MySQL habitual. Después cambiar a la rama corregida e importar la migración sobre esa base de pruebas, crear un usuario DB limitado y configurar las variables indicadas en README.

Levantar el sitio mediante Start-Local.ps1 o PHP con router.php. Para T30 levantar un segundo servidor sin excepción HTTP; para T31 usar un tercero con DB_USER=root. Instalar Playwright en tests y ejecutar tests/verify.cjs. La suite registra respuestas, prueba caducidad manipulando únicamente sus propias sesiones y genera capturas. Comprobar además php -l en los ocho archivos PHP.

Publicación y verificación remota

La publicación se realizó sin force-push y se verificó con git ls-remote y con la consulta de ramas de GitHub. La rama base apunta al commit original indicado arriba; la rama corregida conserva ese ancestro y el commit de código corregido, seguido por los commits documentales. Publish-Branches.ps1 permite volver a publicar y comprobar exclusivamente estas dos ramas.

Riesgos pendientes y conclusiones

Pendiente	Acción para cerrar
Transporte real	Desplegar certificado válido y comprobar nombre, cadena, protocolos, HTTPS y cookie Secure. NETWORK-1 permanece NC.
Componentes del entorno	Actualizar PHP y MariaDB y revisar sus vulnerabilidades conocidas. No se distribuyen ni actualizan los binarios del equipo. CODE-2 permanece NC.
Identificación y conservación	El correo identifica la cuenta y un hash de IP limita intentos. Eliminar cargas de terceros reduce exposición, pero no garantiza anonimato. PRIVACY-2 permanece NC. Programar purga de sesiones, contadores vencidos y logs.
Uso público y abuso	Añadir verificación de correo, recuperación segura, controles de registro y mitigación distribuida de intentos. El límite por IP puede afectar usuarios de una red compartida; la eliminación de cuenta requiere revisión de abuso adicional.
Operación del servidor	Verificar ACL, cifrado de copias y logs privados. Servir siempre mediante el router o reglas equivalentes. La CSP admite estilos inline por compatibilidad con el diseño; los scripts inline están bloqueados.
Ámbito funcional	Carrito, contacto y donaciones no procesan operaciones comerciales. No se probó una aplicación Android/iOS, un dispositivo móvil real ni una WebView embebida.

La revisión resolvió más de cinco problemas concretos y restableció un flujo funcional de registro, acceso, sesión y eliminación de cuenta con datos ficticios. Las pruebas muestran una reducción de las exposiciones detectadas: SQL ya no se concatena con las entradas, el esquema no se descarga bajo el router, las solicitudes inválidas se rechazan y la sesión anterior deja de autorizar el acceso al cerrar.

El resultado es válido para el código y el laboratorio descritos. Las 32 comprobaciones satisfactorias no implican ausencia de otras vulnerabilidades ni cumplimiento integral de MASVS. El checklist conserva explícitamente las verificaciones incompletas y las exclusiones para evitar atribuir a la aplicación pruebas que no se realizaron.

Referencias

[1] OWASP MASVS versión 2.1.0

[2] OWASP MASVS controles y alcance

[3] OWASP Mobile Application Security Testing Guide

[4] Material de clase aportado: Tarea Movil Integral.pptx, diapositivas 48 a 58. Matriz de riesgo, método, mínimos de corrección y estructura de entrega.